

# **Vulnerability Assessment Report**

## **DownUnderNewsz - Vulnerability Assessment Report**

**The Down Under News (DownUnderNewsz)**  
22 Arthur St  
Fairfield VIC 3078, Australia

**Flinders University**  
Sturt Road, Bedford Park SA  
5042

September 18, 2026

Report Version: 1.0

# Table of Contents

|                                                              |           |
|--------------------------------------------------------------|-----------|
| <b>List of Figures .....</b>                                 | <b>3</b>  |
| <b>1 Document Control .....</b>                              | <b>4</b>  |
| 1.1 Team .....                                               | 4         |
| 1.2 List of Changes .....                                    | 4         |
| <b>2 Executive Summary .....</b>                             | <b>5</b>  |
| 2.1 Overview .....                                           | 5         |
| 2.2 Identified Vulnerabilities .....                         | 6         |
| <b>3 Methodology .....</b>                                   | <b>8</b>  |
| 3.1 Objective .....                                          | 8         |
| 3.2 Scope .....                                              | 8         |
| 3.3 User Accounts and Permissions .....                      | 9         |
| <b>4 Findings .....</b>                                      | <b>10</b> |
| C1: Exposed Backend Application Server (Port 5000) .....     | 10        |
| H1: Admin Credentials Disclosed in API Response .....        | 12        |
| H2: Anonymous FTP Access Enabled .....                       | 13        |
| M1: Missing HTTP Security Headers .....                      | 15        |
| M2: Server Information Disclosure .....                      | 17        |
| M3: Missing HSTS on TLS Endpoints .....                      | 18        |
| L1: TLS CBC-Mode Ciphers Enabled (LUCKY13 Potential) .....   | 19        |
| I1: Media Server Backend Unavailable (502 Bad Gateway) ..... | 20        |
| <b>5 Disclaimer .....</b>                                    | <b>21</b> |
| <b>A Appendix .....</b>                                      | <b>22</b> |
| A.1 Static Appendix Section .....                            | 22        |
| A.2 Assessment Tools .....                                   | 22        |
| A.3 Remediation Priority Matrix .....                        | 22        |

## List of Figures

|                                                             |   |
|-------------------------------------------------------------|---|
| Figure 1 - Distribution of identified vulnerabilities ..... | 7 |
|-------------------------------------------------------------|---|

# 1 Document Control

## 1.1 Team

| Contact | Details          | Role      |
|---------|------------------|-----------|
| ClawSec | Autonomous agent | Pentester |

## 1.2 List of Changes

| Version | Description                             | Date         |
|---------|-----------------------------------------|--------------|
| 1.0     | Initial vulnerability assessment report | Sep 18, 2026 |

## 2 Executive Summary

### 2.1 Overview

#### Overview

ClawSec conducted a comprehensive vulnerability assessment of The Down Under News (DownUnderNewsz) digital infrastructure on September 18, 2026. The assessment covered the organization's primary website, media server, and associated network infrastructure.

#### Key Findings

The assessment identified **8 security findings** across the organization's digital assets:

| Severity      | Count |
|---------------|-------|
| Critical      | 1     |
| High          | 2     |
| Medium        | 2     |
| Low           | 2     |
| Informational | 1     |

#### Critical Concern

**The most urgent finding requires immediate action.** The backend application server is publicly accessible on port 5000, completely bypassing the organization's security controls. This means attackers can directly access administrative functions and sensitive data without any restrictions. **This vulnerability should be addressed within 24 hours.**

#### High-Priority Issues

Two additional high-severity issues were identified:

1. **Anonymous FTP Access:** The media server allows anyone to download files without authentication, potentially exposing proprietary content and business documents.
2. **Admin Credentials Exposed:** The public API inadvertently reveals administrator account details, which could enable targeted attacks against administrative accounts.

#### Positive Observations

The assessment confirmed that the application is **not vulnerable** to several common attack types:

- SQL Injection (database attacks)
- Cross-Site Scripting (XSS)

- Server-Side Template Injection
- Path Traversal attacks

The website uses modern TLS encryption (1.2/1.3) with strong cipher configurations, and the admin panel properly requires authentication.

## Recommended Actions

1. **Immediate (24-48 hours)**: Block public access to port 5000
2. **Urgent (1 week)**: Disable anonymous FTP access and fix API data exposure
3. **Short-term (2-4 weeks)**: Implement security headers and resolve remaining medium/low findings

## Business Impact

If left unaddressed, these vulnerabilities could result in:

- Unauthorized access to administrative systems
- Data theft or manipulation
- Reputational damage
- Potential regulatory compliance issues

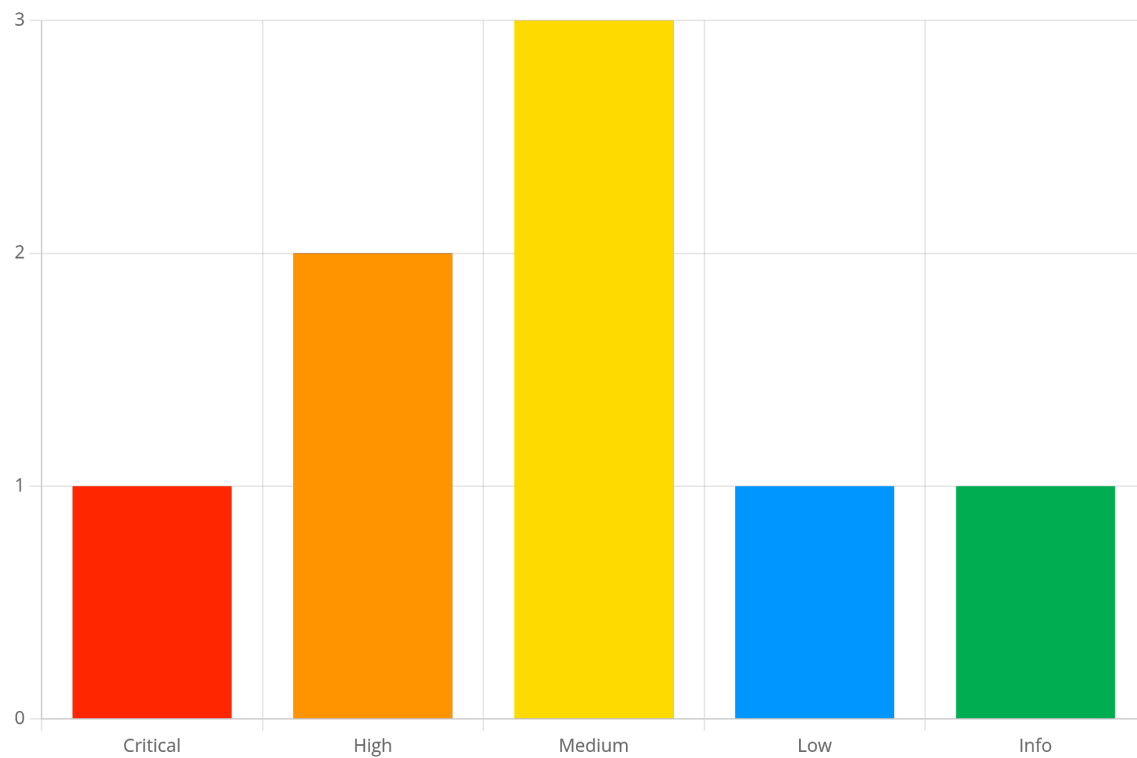
We recommend prioritizing remediation based on the severity ratings provided in this report.

## 2.2 Identified Vulnerabilities

| #  | CVSS | Description                                        | Page |
|----|------|----------------------------------------------------|------|
| C1 | 9.8  | Exposed Backend Application Server (Port 5000)     | 10   |
| H1 | 7.5  | Admin Credentials Disclosed in API Response        | 12   |
| H2 | 7.5  | Anonymous FTP Access Enabled                       | 13   |
| M1 | 5.3  | Missing HTTP Security Headers                      | 15   |
| M2 | 5.3  | Server Information Disclosure                      | 17   |
| M3 | 4.8  | Missing HSTS on TLS Endpoints                      | 18   |
| L1 | 3.7  | TLS CBC-Mode Ciphers Enabled (LUCKY13 Potential)   | 19   |
| I1 | 0.0  | Media Server Backend Unavailable (502 Bad Gateway) | 20   |

## Vulnerability Overview

In the course of this penetration test **1 Critical**, **2 High**, **3 Medium**, **1 Low** and **1 Info** vulnerabilities were identified:



**Figure 1 - Distribution of identified vulnerabilities**

## 3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

### 3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasible, seamless and cost-affective such approach is.

### 3.2 Scope

#### Scope Overview

This vulnerability assessment covered all digital assets belonging to The Down Under News organization, including web applications, servers, and network services.

#### In-Scope Assets

| System                        | IP Address     | Description                                               |
|-------------------------------|----------------|-----------------------------------------------------------|
| thedownundernews.online       | 51.161.130.70  | Primary website and news platform                         |
| www.thedownundernews.online   | 51.161.130.70  | WWW alias for main website                                |
| media.thedownundernews.online | 51.161.131.195 | Media content server                                      |
| Main VPS                      | 51.161.130.70  | Primary server (OVH Australia) - Ports: 22, 80, 443, 5000 |
| Media VPS                     | 51.161.131.195 | Media server (OVH Australia) - Ports: 21, 22, 80, 443     |

## Methodology

The assessment followed industry-standard methodologies including:

- **Service Enumeration:** Port scanning and service fingerprinting
- **Web Application Testing:** OWASP Top 10 vulnerability testing
- **API Security Testing:** Authentication, authorization, and data exposure analysis
- **SSL/TLS Analysis:** Certificate validation and cipher suite evaluation
- **FTP Service Testing:** Authentication and access control testing
- **Infrastructure Review:** Server configuration and exposure analysis

## Testing Categories

The following vulnerability categories were tested:

- SQL Injection - **Not Vulnerable**
- Cross-Site Scripting (XSS) - **Not Vulnerable** (properly sanitized)
- Server-Side Template Injection - **Not Vulnerable**
- Path Traversal - **Not Vulnerable**
- Authentication Controls - Admin panel requires authentication
- TLS Configuration - TLS 1.2/1.3 with strong ciphers

## Limitations

The following activities were **excluded** from scope:

- Credential brute-forcing
- Destructive testing
- Social engineering
- Denial of service testing

**Note:** The media server backend was unavailable during testing (502 Bad Gateway errors), limiting the depth of testing possible on that asset.

## 3.3 User Accounts and Permissions

No user credentials were provided for this assessment. All testing was performed from an unauthenticated perspective.

## 4 Findings

| C1: Exposed Backend Application Server (Port 5000) |                                                                                                                                                                                                                                                                                                         |
|----------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Score                                              | 9.8 (Critical)                                                                                                                                                                                                                                                                                          |
| Vector string                                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H                                                                                                                                                                                                                                                            |
| Target                                             | 51.161.130.70:5000 (thedownundernews.online backend)                                                                                                                                                                                                                                                    |
| References                                         | <ul style="list-style-type: none"><li>• <a href="https://cwe.mitre.org/data/definitions/284.html">https://cwe.mitre.org/data/definitions/284.html</a></li><li>• <a href="https://owasp.org/Top10/A01_2021-Broken_Access_Control/">https://owasp.org/Top10/A01_2021-Broken_Access_Control/</a></li></ul> |

### Overview

The Gunicorn backend application server is directly accessible on port 5000 without any authentication or access controls. This completely bypasses the nginx reverse proxy security layer, exposing administrative functionality and sensitive data.

### Details

During the assessment, it was discovered that the Python/Gunicorn backend server running on port 5000 is publicly accessible. While the nginx reverse proxy on ports 80/443 is intended to be the only entry point, the backend server accepts connections directly from the internet.

This exposure allows attackers to:

- Access the admin panel (/admin) without proxy-level restrictions
- Retrieve sensitive API data including admin credentials
- Bypass any rate limiting or access controls implemented at the proxy level
- Access internal endpoints not intended for public consumption

#### Evidence:

- Direct access to <http://51.161.130.70:5000/> returns the full website
- <http://51.161.130.70:5000/admin> returns 200 OK (2,894 bytes)
- <http://51.161.130.70:5000/api/articles> exposes admin user details
- Server header confirms: "Server: gunicorn"

**Business Impact:** Complete compromise of application security model. The multi-tier architecture is rendered ineffective as attackers can bypass all proxy-level security controls. This could lead to unauthorized administrative access, data theft, and system compromise.

## Recommendation

1. **IMMEDIATE:** Block port 5000 from public internet access using firewall rules (iptables/ufw)
2. Configure Gunicorn to listen only on localhost (127.0.0.1:5000)
3. Implement application-level authentication on all sensitive endpoints
4. Consider network segmentation to isolate backend services

## H1: Admin Credentials Disclosed in API Response

|               |                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Score         | 7.5 (High)                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Vector string | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N                                                                                                                                                                                                                                                                                                                                                                                    |
| Target        | <a href="https://thedownundernews.online/api/articles">https://thedownundernews.online/api/articles</a>                                                                                                                                                                                                                                                                                                                         |
| References    | <ul style="list-style-type: none"><li>• <a href="https://cwe.mitre.org/data/definitions/200.html">https://cwe.mitre.org/data/definitions/200.html</a></li><li>• <a href="https://cwe.mitre.org/data/definitions/359.html">https://cwe.mitre.org/data/definitions/359.html</a></li><li>• <a href="https://owasp.org/Top10/A01_2021-Broken_Access_Control/">https://owasp.org/Top10/A01_2021-Broken_Access_Control/</a></li></ul> |

### Overview

The public API endpoint exposes administrator account information including username, email address, role, and account creation timestamp.

### Details

The /api/articles endpoint returns article data that includes full author details. For articles authored by the administrator, this exposes:

- Username: admin
- Email: admin@thedownundernews.it.com
- Role: admin
- Account status: active
- Creation date: 2026-09-13T13:16:02.003617+00:00

This information disclosure provides attackers with valid usernames and email addresses for potential credential attacks, phishing, or social engineering.

#### Evidence:

- GET request to /api/articles returns JSON with author objects
- Author object contains: {"username": "admin", "email": "admin@thedownundernews.it.com", "role": "admin", "is\_active": true}

**Business Impact:** Exposure of admin credentials enables targeted attacks against administrative accounts. The email address can be used for spear-phishing, and the username confirms valid authentication targets for brute-force attempts.

### Recommendation

1. Implement API response filtering to exclude sensitive user fields
2. Create a separate "public profile" object with only necessary display information
3. Review all API endpoints for similar information disclosure
4. Consider implementing field-level access controls based on authentication status

| <b>H2: Anonymous FTP Access Enabled</b> |                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-----------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Score                                   | 7.5 (High)                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Vector string                           | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N                                                                                                                                                                                                                                                                                                                                                                                        |
| Target                                  | 51.161.131.195:21 (media.thedownundernews.online)                                                                                                                                                                                                                                                                                                                                                                                   |
| References                              | <ul style="list-style-type: none"> <li>• <a href="https://cwe.mitre.org/data/definitions/284.html">https://cwe.mitre.org/data/definitions/284.html</a></li> <li>• <a href="https://cwe.mitre.org/data/definitions/552.html">https://cwe.mitre.org/data/definitions/552.html</a></li> <li>• <a href="https://owasp.org/Top10/A01_2021-Broken_Access_Control/">https://owasp.org/Top10/A01_2021-Broken_Access_Control/</a></li> </ul> |

## Overview

The FTP server on the media subdomain allows anonymous login, providing unauthenticated access to media files including documents and images.

## Details

The vsftpd 3.0.5 FTP server on the media server (51.161.131.195) permits anonymous authentication. Upon connecting with anonymous credentials, users gain read access to the FTP root directory containing media assets.

### Files currently exposed:

- 37550846eae5457d93ddd8e1d2faeaca.html (76 bytes)
- 58e75939c3d24841806d3a069e919576.png (230,599 bytes)
- 66ea642847be4ef0a800fb8cb8432d79.png (167,268 bytes)
- d2273a1a2576489fb419cc1049c4c62f.pdf (624,807 bytes)

Additionally, all FTP communications occur in plaintext (unencrypted), exposing any credentials used to potential interception.

### Evidence:

- nmap ftp-anon script confirms: "Anonymous FTP login allowed (FTP code 230)"
- FTP banner: "vsFTPD 3.0.5"
- Directory listing shows 4 files with read permissions

**Business Impact:** Unauthorized access to media files that may contain proprietary content, internal documents, or sensitive information. The PDF file (624KB) is particularly concerning as it may contain business documents. Plaintext FTP also risks credential exposure if staff use authenticated sessions.

## Recommendation

1. Disable anonymous FTP access in vsftpd configuration (anonymous\_enable=NO)
2. Migrate to SFTP (SSH-based file transfer) for encrypted communications

3. Implement proper authentication for all file access
4. Review exposed files for sensitive content and assess data breach implications
5. Consider removing FTP service entirely if not business-critical

| <b>M1: Missing HTTP Security Headers</b> |                                                                                                                                                                                                                                                                                                                    |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Score                                    | 5.3 (Medium)                                                                                                                                                                                                                                                                                                       |
| Vector string                            | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N                                                                                                                                                                                                                                                                       |
| Target                                   | <ul style="list-style-type: none"> <li>• <a href="https://thedownundernews.online/">https://thedownundernews.online/</a></li> <li>• <a href="https://media.thedownundernews.online/">https://media.thedownundernews.online/</a></li> </ul>                                                                         |
| References                               | <ul style="list-style-type: none"> <li>• <a href="https://cwe.mitre.org/data/definitions/693.html">https://cwe.mitre.org/data/definitions/693.html</a></li> <li>• <a href="https://owasp.org/Top10/A05_2021-Security_Misconfiguration/">https://owasp.org/Top10/A05_2021-Security_Misconfiguration/</a></li> </ul> |

## Overview

The web application is missing critical HTTP security headers that protect against common web attacks including clickjacking, MIME-type sniffing, and protocol downgrade attacks.

## Details

Security header analysis revealed the following deficiencies:

### Missing Headers:

- Strict-Transport-Security (HSTS): Not implemented - vulnerable to SSL stripping
- Content-Security-Policy (CSP): Not implemented - no XSS mitigation
- X-Content-Type-Options: Not implemented - MIME sniffing possible
- Referrer-Policy: Not implemented - referrer leakage
- Permissions-Policy: Not implemented - unrestricted browser features

### Present but Suboptimal:

- X-Frame-Options: Present (deprecated, should use CSP frame-ancestors)
- Server: nginx (information disclosure)

### Evidence:

- `curl -sI https://thedownundernews.online/` shows only Server header
- No security headers present in response

**Business Impact:** Without these protections, the application is more susceptible to:

- Man-in-the-middle attacks (no HSTS)
- Cross-site scripting exploitation (no CSP)
- Clickjacking attacks (deprecated X-Frame-Options only)
- Browser feature abuse (no Permissions-Policy)

## Recommendation

Add the following headers in nginx configuration:

```
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains; preload"
always;
add_header Content-Security-Policy "default-src 'self'; script-src 'self'; style-src
'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://
fonts.gstatic.com; img-src 'self' data: https;; frame-ancestors 'none';" always;
add_header X-Content-Type-Options "nosniff" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
add_header Permissions-Policy "geolocation=(), microphone=(), camera=()" always;
```

| M2: Server Information Disclosure |                                                                                                                                                                                                                                                                                                         |
|-----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Score                             | 5.3 (Medium)                                                                                                                                                                                                                                                                                            |
| Vector string                     | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N                                                                                                                                                                                                                                                            |
| Target                            | All endpoints (thedownundernews.online, media.thedownundernews.online, 51.161.130.70, 51.161.131.195)                                                                                                                                                                                                   |
| References                        | <ul style="list-style-type: none"><li>• <a href="https://cwe.mitre.org/data/definitions/200.html">https://cwe.mitre.org/data/definitions/200.html</a></li><li>• <a href="https://owasp.org/Top10/A01_2021-Broken_Access_Control/">https://owasp.org/Top10/A01_2021-Broken_Access_Control/</a></li></ul> |

## Overview

The web server and backend disclose software identification in HTTP response headers, aiding attackers in fingerprinting the technology stack.

## Details

HTTP response headers reveal:

- Main server: "Server: nginx"
- Backend: "Server: gunicorn"
- FTP server: "vsFTPd 3.0.5"

While version numbers are not fully disclosed for nginx, the software identification assists attackers in:

- Identifying potential version-specific vulnerabilities
- Tailoring exploits for the detected software
- Reducing reconnaissance effort

### Evidence:

- curl -sI responses show Server headers
- FTP SYST command returns version information

**Business Impact:** Minimal direct impact, but reduces the effort required for targeted attacks and contributes to the overall attack surface.

## Recommendation

1. Configure nginx: server\_tokens off;
2. Configure Gunicorn to suppress server header or use nginx to strip it
3. Configure vsftpd: ftpd\_banner=Welcome to FTP service (custom banner)

| <b>M3: Missing HSTS on TLS Endpoints</b> |                                                                                                                                                                                                                                                                                                              |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Score                                    | 4.8 (Medium)                                                                                                                                                                                                                                                                                                 |
| Vector string                            | CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N                                                                                                                                                                                                                                                                 |
| Target                                   | <ul style="list-style-type: none"> <li>• <a href="https://thedownundernews.online/">https://thedownundernews.online/</a></li> <li>• <a href="https://media.thedownundernews.online/">https://media.thedownundernews.online/</a></li> </ul>                                                                   |
| References                               | <ul style="list-style-type: none"> <li>• <a href="https://cwe.mitre.org/data/definitions/319.html">https://cwe.mitre.org/data/definitions/319.html</a></li> <li>• <a href="https://owasp.org/Top10/A02_2021-Cryptographic_Failures/">https://owasp.org/Top10/A02_2021-Cryptographic_Failures/</a></li> </ul> |

## Overview

Neither web endpoint implements HTTP Strict Transport Security (HSTS), leaving users vulnerable to protocol downgrade and man-in-the-middle attacks.

## Details

While both domains support HTTPS with valid Let's Encrypt certificates and redirect HTTP to HTTPS, the absence of HSTS headers means:

- Browsers will still attempt initial HTTP connections
- Active network attackers can intercept and prevent the HTTPS redirect
- Users are vulnerable to SSL stripping attacks on untrusted networks

Both servers were confirmed to lack this header during SSL/TLS analysis using testssl.

### Evidence:

- testssl output: "HSTS: NOT offered"
- curl -sI shows no Strict-Transport-Security header

**Business Impact:** Users accessing the site from public WiFi, corporate networks, or compromised networks may have their sessions intercepted before the HTTPS redirect occurs, potentially exposing credentials or session tokens.

## Recommendation

1. Add HSTS header: Strict-Transport-Security: max-age=31536000; includeSubDomains
2. After confirming proper HTTPS operation, consider HSTS preloading
3. Ensure all subdomains also support HTTPS before adding includeSubDomains

| <b>L1: TLS CBC-Mode Ciphers Enabled (LUCKY13 Potential)</b> |                                                                                                                                                                                                                                                                                          |
|-------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Score                                                       | 3.7 (Low)                                                                                                                                                                                                                                                                                |
| Vector string                                               | CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N                                                                                                                                                                                                                                             |
| Target                                                      | <ul style="list-style-type: none"> <li>• <a href="https://thedownundernews.online/">https://thedownundernews.online/</a></li> <li>• <a href="https://media.thedownundernews.online/">https://media.thedownundernews.online/</a></li> </ul>                                               |
| References                                                  | <ul style="list-style-type: none"> <li>• <a href="https://nvd.nist.gov/vuln/detail/CVE-2013-0169">https://nvd.nist.gov/vuln/detail/CVE-2013-0169</a></li> <li>• <a href="https://cwe.mitre.org/data/definitions/310.html">https://cwe.mitre.org/data/definitions/310.html</a></li> </ul> |

## Overview

Both TLS endpoints support CBC-mode cipher suites which are theoretically vulnerable to the LUCKY13 timing attack.

## Details

SSL/TLS analysis revealed that both servers support TLS 1.2 cipher suites using CBC (Cipher Block Chaining) mode, including:

- ECDHE-ECDSA-AES128-SHA256
- ECDHE-ECDSA-AES256-SHA384

While modern TLS implementations include mitigations for LUCKY13, the presence of these ciphers represents a theoretical weakness. AEAD ciphers (GCM, ChaCha20-Poly1305) are preferred.

### Evidence:

- testssl output: "LUCKY13 (CVE-2013-0169): potentially vulnerable (uses TLS CBC ciphers)"
- CBC ciphers listed but not preferred over AEAD alternatives

**Business Impact:** Low practical impact due to attack complexity, but represents deviation from TLS best practices. Modern browsers will typically negotiate AEAD ciphers when available.

## Recommendation

1. Disable CBC-mode ciphers in nginx SSL configuration
2. Prioritize AEAD ciphers (GCM, ChaCha20-Poly1305) in cipher ordering
3. Example nginx configuration: `ssl_ciphers 'ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-ECDSA-AES256-GCM-SHA384:ECDHE-ECDSA-CHACHA20-POLY1305';`

## I1: Media Server Backend Unavailable (502 Bad Gateway)

|               |                                        |
|---------------|----------------------------------------|
| Score         | 0.0 (Info)                             |
| Vector string | N/A                                    |
| Target        | https://media.thedownundernews.online/ |
| References    | -                                      |

### Overview

The media subdomain returns HTTP 502 Bad Gateway errors, indicating a backend service failure.

### Details

All requests to media.thedownundernews.online return 502 errors from the nginx reverse proxy. This indicates the backend application server is either:

- Not running
- Misconfigured
- Unable to communicate with nginx

While not a security vulnerability per se, this represents an availability issue and may indicate infrastructure problems that could mask other security concerns.

#### Evidence:

- curl -sI https://media.thedownundernews.online/ returns HTTP/1.1 502 Bad Gateway
- Consistent across multiple test requests

**Business Impact:** Media content is unavailable to users. If the subdomain was intended to serve media files, content delivery is impacted.

### Recommendation

1. Review backend service logs for the media subdomain
2. Ensure backend application is running and properly configured
3. Verify nginx upstream configuration points to correct backend address

## 5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerability assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

# A Appendix

## A.1 Static Appendix Section

## A.2 Assessment Tools

The following tools were used during this assessment:

- **nmap**: Network discovery and service enumeration
- **testssl**: SSL/TLS configuration analysis
- **curl**: HTTP request testing and header analysis
- **FTP client**: FTP service testing
- **Custom scripts**: API endpoint analysis

## Risk Rating Methodology

| Severity      | CVSS Score Range | Description                                       |
|---------------|------------------|---------------------------------------------------|
| Critical      | 9.0 - 10.0       | Immediate exploitation likely with severe impact  |
| High          | 7.0 - 8.9        | Significant risk requiring urgent attention       |
| Medium        | 4.0 - 6.9        | Moderate risk requiring planned remediation       |
| Low           | 0.1 - 3.9        | Minor risk to be addressed in regular maintenance |
| Informational | N/A              | Observations and best practice recommendations    |

## A.3 Remediation Priority Matrix

### Immediate Actions (24-48 hours)

| Finding                     | Action Required                  |
|-----------------------------|----------------------------------|
| Exposed Backend (Port 5000) | Block public access via firewall |

### Urgent Actions (1 Week)

| Finding                  | Action Required                   |
|--------------------------|-----------------------------------|
| Anonymous FTP Access     | Disable anonymous login in vsftpd |
| Admin Credentials in API | Implement response filtering      |

## Short-Term Actions (2-4 Weeks)

| Finding                       | Action Required                       |
|-------------------------------|---------------------------------------|
| Missing Security Headers      | Add HSTS, CSP, X-Content-Type-Options |
| Missing HSTS                  | Configure Strict-Transport-Security   |
| CBC Cipher Suites             | Disable CBC-mode ciphers              |
| Server Information Disclosure | Suppress server version headers       |

## Ongoing Monitoring

| Finding                 | Action Required                         |
|-------------------------|-----------------------------------------|
| Media Server 502 Errors | Investigate and restore backend service |